

Soften Material

คู่มือพัฒนาระบบสำหรับทีม
เวอร์ชันเอกสาร 0.1 · สิงหาคม 2026

ชื่อโปรเจกต์	Soften Material
กลุ่มผู้ใช้	นักศึกษาวิศวกรรมซอฟต์แวร์ มหาวิทยาลัยธรรมศาสตร์
โดเมนที่อนุญาตให้สมัคร	เฉพาะ @dome.tu.ac.th
โค้ดเบสตั้งต้น	Next.js 16 (App Router), React 19, Tailwind CSS 4

เอกสารนี้เป็นสเปกสำหรับนักพัฒนา ใช้เป็นแนวทาง implement ตามเฟส อย่าข้ามเฟสโดยไม่มีเหตุผล (เช่น อย่าทำอัปโหลดไฟล์ก่อน auth โดเมน TU ทำงาน)

สารบัญ

- 1. [เว็บไซต์นี้คืออะไร](#)
- 2. [บทบาทและสิทธิ์](#)
- 3. [กฎความปลอดภัยพื้นฐาน](#)
- 4. [เฟส 0 — เตรียมโปรเจกต์](#)
- 5. [เฟส 1 — ยืนยันตัวตน \(โดเมน TU\)](#)
- 6. [เฟส 2 — รายวิชาและบทบาท](#)
- 7. [เฟส 3 — อัปโหลดและอ่าน PDF](#)
- 8. [เฟส 4 — ความปลอดภัยขั้นสูงและคุณภาพเนื้อหา](#)
- 9. [เฟส 5 — ค้นหาและฟีดแบ็กการเรียน](#)
- 0. [นอกสโคป](#)
- 1. [เช็กलिสรีวิว PR](#)
- 2. [ภาคผนวก](#)

1. เว็บไซต์นี้คืออะไร

Soften Material คือเว็บคลังเอกสารเรียนของหลักสูตรวิศวกรรมซอฟต์แวร์ (Soft-En) มหาวิทยาลัยธรรมศาสตร์ นักศึกษาใช้ที่นี่เพื่อหาและดาวน์โหลดสื่อที่กระจายอยู่ตามกรุ๊ปแชทหรือโดรฟ์ส่วนตัว ให้รวมเป็นแคตตาล็อกเดียว ค้นได้ตามรหัสวิชา ปีการศึกษา และประเภทไฟล์ มีการยืนยันตัวตนและบันทึกการเข้าถึง

1.1 สิ่งที่เก็บในระบบ

- ชีทสรุป / เอกสารอ่านประกอบ
- ข้อสอบเก่า (กลางภาค, ปลายภาค, ควิช) และเฉลย (ถ้ามี — อาจซ่อนแยกจากข้อสอบ)

- แบบฝึกหัด / งาน / ชีทแล็บ
- ในเฟสถัดไปอาจเพิ่มสไลด์บรรยายหรือโน้ตเพิ่มเติม

1.2 ใครใช้ได้

- **ใช้ได้:** คนที่มีอีเมล @dome.tu.ac.th และยืนยันอีเมลแล้ว
- **ใช้ไม่ได้:** อีเมลภายนอก (Gmail, Hotmail ฯลฯ) และบัญชียังไม่ยืนยันอีเมล

ทางเลือกในอนาคต (ยังไม่ทำในเฟสแรก): อนุญาตโดเมนบุคลากร เช่น @tu.ac.th ถ้าต้องการให้อาจารย์เข้าได้

1.3 ปัญหาที่เว็บนี้แก้

- ไฟล์ซ้ำ ชื่อไม่เป็นระบบ หาข้อสอบปีเก่าไม่เจอ
- ไม่รู้ว่าไฟล์ไหนเป็นฉบับล่าสุด
- คนนอกหลักสูตรไม่ควรเข้าถึงคลังข้อสอบของรายวิชา

1.4 สิ่งที่เว็บนี้ไม่ใช่

- ไม่ใช่ระบบเรียนแทน TU Learn / LMS (ไม่มีเกรด ส่งงานตรวจอัตโนมัติ)
- ไม่ใช่โซเชียลเน็ตเวิร์กหรือแชทเรียลไทม์
- ไม่เผยแพร่ไฟล์ข้อสอบให้เครื่องมือค้นหาอินเทอร์เน็ต index
- ไม่ใช่ที่เก็บไฟล์ส่วนตัวไม่จำกัดประเภท (รับเฉพาะชนิดที่กำหนด เช่น PDF ในเฟสแรก)

1.5 หลักการออกแบบสั้น ๆ

- ปิดเป็นค่าเริ่ม: หน้าที่เป็นคลังต้องล็อกอินแล้ว
- สิทธิ์ตรวจที่เซิร์ฟเวอร์ทุกครั้ง รวมถึงดาวโหลดไฟล์
- เนื้อหาเข้าคิวอนุมัติ ก่อนเผยแพร่ (contributor อัปโหลด → moderator อนุมัติ → student เห็น)

2. บทบาทและสิทธิ์

บทบาท	สิทธิ์หลัก
Student	ดูค้นพรีวิวดาวโหลดไฟล์ที่ เผยแพร่แล้ว บุกมาร์ก ดูประวัติตัวเอง
Contributor	สิทธิ์ student + อัปโหลดฉบับร่าง แก้ไฟล์ที่ตัวเองอัปโหลด
Moderator	สิทธิ์ contributor + อนุมัติ/ปฏิเสธ/ซ่อนไฟล์ ดูคิวรอตรวจ
Admin	สิทธิ์ moderator + จัดการผู้ใช้ บทบาท รายวิชา การตั้งค่าความปลอดภัย

บัญชีใหม่หลังยืนยันอีเมลได้บทบาท **Student** เป็นค่าเริ่ม Admin เป็นคนตั้ง contributor/moderator
 ทุกการดาวโหลดและการกระทำของแอดมินต้องเช็คทั้ง บทบาท และ สถานะเนื้อหา (draft / pending / published / hidden)

3. กฎความปลอดภัยพื้นฐาน

ใช้กับทุกเฟส ไม่รอเฟส 4

1. อนุญาตสมัคร/ล็อกอินเฉพาะอีเมลที่ลงท้าย `@dome.tu.ac.th` — บังคับที่เซิร์ฟเวอร์และที่ระบบ auth ไม่พึ่งการซ่อนปุ่มใน UI
 2. ทำอีเมลเป็นตัวพิมพ์เล็ก ตัดช่องว่าง ก่อนเปรียบเทียบโดเมน
 3. บัญชียังไม่ verify อีเมล เข้าคลังไฟล์ไม่ได้
 4. cookie session เป็น `httpOnly`, `Secure`, `SameSite` ที่เหมาะสม
 5. จำกัดอัตรา (rate limit) ที่ login, สมัคร, รีเซ็ตรหัส, ดาวน์โหลด
 6. ไฟล์ไม่วางบน bucket สาธารณะแบบ URL คงที่ตลอดกาล ใช้ลิงก์ลงชื่อมีวันหมดอายุ และเช็คสิทธิ์ก่อนออกลิงก์
 7. ความลับทั้งหมดอยู่ใน environment ไม่ commit ไฟล์ `.env` ที่มีค่าจริง
 8. อย่าเชื่อ `userId` จาก body ของไคลเอนต์โดยไม่เทียบกับ session
-

เฟส 0 — เตรียมโปรเจกต์

เป้าหมาย: โปรเจกต์รันและต่อเอกสารได้ ยังไม่มีคลังจริง

งานหลัก

- คงโครงสร้าง Next.js ที่มี (`src/app`, `src/components`, `src/features` ตามที่หน้าแรกแนะนำ)
- ไฟล์ `.env.example` ระบุตัวแปรที่ต้องมี (ว่าง ๆ ไม่ใส่ secret)
- README ชี้มาที่เอกสารฉบับนี้ในโฟลเดอร์ `docs/`
- เส้นทางหน้าเว็บว่าง ๆ ตามที่ต้องใช้ในเฟสถัดไปได้วาง skeleton ได้ แต่ไม่ต้องมี logic ครบ

เกณฑ์รับงาน (DoD)

- `npm run build` ผ่าน
 - ไม่มี secret ใน git
 - นักพัฒนาใหม่เปิด README แล้วรู้ว่าสเปกอยู่ที่ `docs/soften-material-dev-spec.th.md`
-

เฟส 1 — ยืนยันตัวตน (โดเมน TU)

เป้าหมาย: มีบัญชีที่เชื่อถือได้เฉพาะอีเมลโดม มธ.

งานหลัก

- หน้าสมัคร เข้าสู่ระบบ ยืนยันอีเมล ลิมิรหัสผ่าน
- สมัครด้วยรหัสผ่าน (นโยบายความยาวขั้นต่ำ) หรือ magic link ตามที่ทีมเลือก — ต้องมียืนยันอีเมล
- ปฏิเสธอีเมลที่ไม่ใช่ `@dome.tu.ac.th` พร้อมข้อความชัดเจนเป็นภาษาไทย
- หลังล็อกอิน ถ้ายังไม่ verify ให้บังคับไปหน้า “กรุณายืนยันอีเมล”
- รีเซ็ตรหัสผ่านส่งได้เฉพาะอีเมลที่ลงทะเบียนแล้ว และเป็น โดเมนที่อนุญาต

- หลังเปลี่ยนรหัสผ่าน ให้ session เก่าใช้ไม่ได้ (invalidate)
- บันทึกเหตุการณ์ auth พื้นฐาน: ล็อกอินสำเร็จ/ล้มเหลว (ไม่เก็บรหัสผ่านใน log)

เกณฑ์รับงาน (DoD)

- สมัครด้วย `someone@gmail.com` ไม่สำเร็จ
 - สมัครด้วย `someone@dome.tu.ac.th` ได้ และต้องกดยืนยันอีเมลก่อนเข้าหน้าคลัง
 - การเดารหัสผ่านถูกจำกัดครั้ง ไม่ทำให้เซิร์ฟเวอร์ล่มง่าย ๆ
 - ทดสอบว่า middleware/layout ไม่เปิดไฟล์ในคลังให้ผู้ที่ไม่ได้ล็อกอิน
-

เฟส 2 — รายวิชาและบทบาท

เป้าหมาย: มีโครง “รายวิชา” และกันหน้าตามบทบาท

งานหลัก

- โมเดลรายวิชา: รหัสวิชา (เช่น SF331) ชื่อวิชา ปี/หลักสูตรถ้าจำเป็น
- บทบาทในฐานะข้อมูล + ผูกกับผู้ใช้
- หน้า: รายการรายวิชา, หน้ารายวิชา (ยังว่างได้), โปรไฟล์, หน้าแอดมินรายชื่อผู้ใช้/ตั้งบทบาท
- กัน route: `/admin` เฉพาะ admin (และ moderator ตามที่ออกแบบ), หน้าอัปโหลดเฉพาะ contributor ขึ้นไป
- Admin สร้าง/แก้รายวิชาได้

เกณฑ์รับงาน (DoD)

- Student เปิด URL แอดมินแล้วถูกปฏิเสธ (ไม่ใช่แค่ซ่อนเมนู)
 - Admin ตั้งคนเป็น contributor ได้
 - รายวิชาแสดงรหัสและชื่ออย่างสม่ำเสมอทั้งระบบ
-

เฟส 3 — อัปโหลดและอ่าน PDF

เป้าหมาย: มีไฟล์ PDF ในคลังแบบปลอดภัยและมี metadata

งานหลัก

- ประเภทเนื้อหา: ชีทสรุป, ข้อสอบ, แบบฝึกหัด (enum ชัดเจน)
- Metadata บังคับ: ชื่อไฟล์ที่แสดง, รายวิชา, ประเภท, ปีการศึกษา, ภาคการศึกษา (ถ้ามี), ผู้อัปโหลด, สถานะ
- Metadata เสริม: แท็ก, ภาษา (ไทย/อังกฤษ), หมายเหตุ, ธง “มีเฉลยแยก”
- อัปโหลด PDF เท่านั้นในเฟสนี้ จำกัดขนาดสูงสุด และตรวจ MIME/นามสกุลที่เซิร์ฟเวอร์
- สถานะเริ่มต้น `pending` จนกว่า moderator จะ `published`
- พรีวิว PDF ในเบราว์เซอร์สำหรับคนที่มีสิทธิ์เห็นไฟล์นั้น
- ดาวน์โหลดผ่าน URL ลงชื่อมีหมดอายุ หลังเช็คสิทธิ์

- Student เห็นเฉพาะ published Contributor เห็นฉบับร่างของตัวเองได้

เกณฑ์รับงาน (DoD)

- คัดลอก URL object storage ตรง ๆ โดยไม่ผ่านระบบแล้วดาวน์โหลดไม่ได้ (หรือลิงก์หมดอายุเร็ว)
- Student ไม่เห็นไฟล์ pending ของคนอื่น
- Moderator อนุมัติแล้ว Student เห็นและปริ๊นได้
- ไฟล์ที่ไม่ใช่ PDF ถูกปฏิเสธ

เฟส 4 — ความปลอดภัยขั้นสูงและคุณภาพเนื้อหา

เป้าหมาย: ลดการรั่วไหลของข้อสอบ และมีร่องรอยการใช้งาน

งานหลัก

- MFA แบบ TOTP สำหรับ Contributor, Moderator, Admin (บังคับหรือแนะนำตามนโยบายทีม — แนะนำบังคับแอดมิน)
- รายการเซสชัน/อุปกรณ์ และป้อนออกจากระบบทุกเครื่อง
- ลายน้ำบนปริ๊นหรือไฟล์ดาวน์โหลดด้วยอีเมลผู้ใช้ (ลดการแชร์ไฟล์ออกนอกกลุ่ม)
- จำกัดจำนวนดาวน์โหลดต่อช่วงเวลา (กันตึงทั้งคลัง)
- Audit log: อนุมัติไฟล์, เปลี่ยนบทบาท, ดาวน์โหลดจำนวนมาก
- ปุ่มรายงานไฟล์ผิด/ซ้ำ/ละเมิด
- ตรวจไฟล์ซ้ำด้วย hash ของเนื้อหา

เกณฑ์รับงาน (DoD)

- แอดมินเปิด MFA ได้และล็อกอินขั้นที่สองทำงาน
- มีบันทึกว่าใครอนุมัติไฟล์ใด เมื่อไร
- การดาวน์โหลดที่ผิดปกติถูกจำกัดหรือถูกตั้งธงใน log

เฟส 5 — ค้นหาและฟีดแบ็กการเรียนรู้

เป้าหมาย: ใช้คลังได้จริงในชีวิตประจำวันของนักศึกษา

งานหลัก

- ค้นหาชื่อไฟล์ รหัสวิชา แท็ก
- ตัวกรอง: ประเภท, ปี, รายวิชา เรียงลำดับตามใหม่ล่าสุดหรือปีข้อสอบ
- บัญมาร์ก / รายการของฉัน
- ดูล่าสุด
- ประวัติการดาวน์โหลดของผู้ใช้ (ผู้ใช้เห็นของตัวเอง แอดมินเห็นภาพรวมได้)
- ฟอรัม “ขอไฟล์ที่ยังไม่มี” เช่น ขอข้อสอบปลายภาคปีหนึ่ง

- แสดงเครดิตผู้อัปโหลดบนหน้ารายละเอียดไฟล์
- (ทางเลือก) แจ้งเตือนเมื่อมีไฟล์ใหม่ในรายวิชาที่ติดตาม, OCR ภายหลัง, สแกนมัลแวร์ก่อนเผยแพร่

เกณฑ์รับงาน (DoD)

- ค้นหารหัสวิชาแล้วเจอไฟล์ที่เกี่ยวข้อง
- บั๊กมาร์กคงอยู่หลังรีเฟรช (ผูกบัญชี ไม่ใช่แค่ memory ในแท็บ)
- คำขอไฟล์ที่ขาดไปถึง moderator/admin ได้

10. นอกสโคป

อย่าทำในเฟส 1-5 ถ้าไม่มีคำขอชัดเจน

- เซทหรือคอมเมนต์แบบเรียลไทม์ทั้งไซต์ (คอมเมนต์ต่อไฟล์เป็นทางเลือกในเฟส 5 และต้องมีโมเดอเรต)
- หน้าสาธารณะที่ Google เก็บ PDF ข้อสอบได้
- สมัครด้วย Google บัญชีส่วนตัวที่ไม่ใช่โดเมน มธ. (ถ้าใช้ Google Login ต้องจำกัด Workspace/โดเมน TU เท่านั้น)
- โพสต์โดยไม่ระบุตัวตน
- คลังไฟล์ไม่จำกัดชนิด (exe, iso ฯลฯ)

11. เช็กลิสต์รีวิว PR

ก่อน merge แต่ละเฟส ให้ตรวจอย่างน้อยดังนี้

- ☐ โดเมนอีเมลถูกบังคับฝังเซิร์ฟเวอร์
- ☐ ไม่มี IDOR (เปลี่ยน id ใน URL แล้วเห็นไฟล์ที่ไม่มีสิทธิ์ไม่ได้)
- ☐ ไม่มี secret ในโค้ดหรือใน PR
- ☐ ฟอรัม mutation มีการกัน CSRF ตามวิธีของเฟรมเวิร์กที่ใช้
- ☐ หัวข้อที่ผู้ใช้อัปโหลดถูก escape ตอนแสดงผล (กัน XSS)
- ☐ HTTPS บนสภาพแวดล้อมจริง, cookie Secure
- ☐ ไฟล์ใหม่เข้าสถานะ pending จนกว่าจะอนุมัติ (ตั้งแต่เฟส 3)
- ☐ มี rate limit จุดที่เสี่ยง brute-force

12. ภาคผนวก

12.1 สถานะไฟล์

สถานะ	ความหมาย
draft	ผู้สร้างยังไม่ส่งตรวจ

pending	รอ moderator
published	นักศึกษาเห็นได้
hidden	ถูกซ่อนหลังเผยแพร่ (takedown)

12.2 ตัวอย่างรหัสวิชา

ใช้รหัสจริงของหลักสูตรตอน implement แคตตาล็อก เช่น รหัสวิชา Soft-En ตามประกาศคณะ — เก็บเป็นข้อมูลในฐาน ไม่ hardcode ทั้งหลักสูตรใน UI ถ้าไม่จำเป็น

12.3 ตัวแปรสภาพแวดล้อม (ตัวอย่างชื่อ)

ค่าจริงห้ามใส่ในเอกสารหรือ git

- URL ของแอป
- คีย์ระบบ auth / Firebase หรือผู้ให้บริการที่เลือก
- connection string ฐานข้อมูล
- คีย์ object storage
- secret สำหรับลงนาม cookie

12.4 ที่อยู่ไฟล์เอกสารนี้

เก็บในรีโปโปรเจกต์เท่านั้น:

`docs/soften-material-dev-spec.th.md`

`docs/soften-material-dev-spec.th.pdf`

ห้ามเขียนไปที่ `/docs` ของเครื่อง (โพลเดอร์ระบบ มักเป็น read-only)